

RELATÓRIO DE

# PENETRATION TEST

Auditoria de Segurança — Rede Interna Empresarial

|               |                                  |
|---------------|----------------------------------|
| CLIENTE       | [Nome da Empresa — Confidencial] |
| AUDITOR       | Mr Joker · Aspiring Pentester    |
| METODOLOGIA   | PTES / OWASP Testing Guide       |
| DATA          | 2 de Maio de 2026                |
| CLASSIFICAÇÃO | CONFIDENCIAL — USO RESTRITO      |
| VERSÃO        | 1.0 — Relatório Final            |

DESENVOLVIDO COM

SHADOW SUITE · THE OFFENSIVE ARSENAL

[github.com/mrjoker-web](#)

# Sumário Executivo

Foi realizada uma auditoria de segurança interna (Penetration Test) à rede da empresa cliente, com autorização formal prévia. O teste decorreu a 2 de Maio de 2026 e teve como objectivo avaliar a superfície de ataque da infraestrutura de rede interna, identificar vulnerabilidades e fornecer recomendações de remediação accionáveis.

O teste foi conduzido utilizando ferramentas da **Shadow Suite** (ShadowScanner, ShadowCVE, Shadow CLI) a partir de um dispositivo móvel com Termux, demonstrando que a metodologia de recon e scanning pode ser executada com recursos mínimos mas com rigor profissional.

| SEVERIDADE | TOTAL | ESTADO |
|------------|-------|--------|
| CRITICAL   | 0     | Nenhum |
| HIGH       | 2     | Aberto |
| MEDIUM     | 1     | Aberto |
| LOW / INFO | 2     | Aberto |

# Âmbito e Metodologia

| PARÂMETRO     | DETALHE                                            |
|---------------|----------------------------------------------------|
| Âmbito        | Rede interna 192.168.1.0/24                        |
| Tipo de teste | Grey Box — conhecimento parcial da infraestrutura  |
| Metodologia   | PTES · OWASP Testing Guide v4                      |
| Ferramentas   | Nmap 7.95 · ShadowScanner · ShadowCVE · Shadow CLI |
| Plataforma    | Android (Termux + Arch Linux proot)                |
| Data          | 2 de Maio de 2026 — 14:00 às 17:30 (UTC)           |
| Autorização   | Autorização verbal e escrita da gestão da empresa  |

## 03

## Hosts Descobertos

---

O scan inicial à rede 192.168.1.0/24 identificou os seguintes hosts activos:

| IP            | DISPOSITIVO                                    | PORTAS ABERTAS                        | RISCO         |
|---------------|------------------------------------------------|---------------------------------------|---------------|
| 192.168.1.224 | Konica Minolta bizhub C452<br>(Impressora)     | 80, 443, 8080 (gSOAP), 8081 (OpenAPI) | <b>MEDIUM</b> |
| 192.168.1.199 | TP-LINK HTTPD/1.0<br>(Câmara IP / NVR)         | 80, 443                               | <b>MEDIUM</b> |
| 192.168.1.219 | TP-LINK Web Switch<br>(Switch gerido)          | 80, 443                               | <b>HIGH</b>   |
| 192.168.1.243 | TP-LINK HTTPD/1.0<br>(Câmara IP)               | 80, 443                               | <b>MEDIUM</b> |
| 192.168.1.254 | Huawei WAP (ONT/Router NOS)<br>[FORA DE SCOPE] | 22 (SSH)                              | <b>INFO</b>   |

## 04

## Findings

---

|            |                                                                                                                                                                                                              |             |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|
| F-001      | <b>Switch gerido com painel web exposto sem autenticação reforçada</b>                                                                                                                                       | <b>HIGH</b> |
| CVSS SCORE | 7.5                                                                                                                                                                                                          |             |
| DESCRIÇÃO  | O switch gerido TP-LINK (192.168.1.219) tem o painel de administração web acessível na rede interna sem autenticação multifactor. Um atacante interno pode aceder às configurações de rede, VLANs e tráfego. |             |
| EVIDÊNCIA  | <code>nmap -sV -p 80,443 192.168.1.219 80/tcp open http Web Switch 443/tcp open ssl/http Liaison Exchange Commerce Suite</code>                                                                              |             |
| IMPACTO    | Acesso à consola de administração do switch permite redireccionar tráfego, criar VLANs, fazer port mirroring e comprometer toda a segmentação de rede.                                                       |             |
| REMEDIACÃO | 1. Activar autenticação forte no painel web 2. Restringir acesso ao painel por IP de gestão 3. Desactivar HTTP — usar apenas HTTPS 4. Actualizar firmware para a versão mais recente                         |             |

|            |                                                                                                                                                                                                           |             |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|
| F-002      | <b>Impressora Konica Minolta bizhub C452 acessível sem autenticação</b>                                                                                                                                   | <b>HIGH</b> |
| CVSS SCORE | 7.2                                                                                                                                                                                                       |             |
| DESCRIÇÃO  | O painel web da impressora Konica Minolta bizhub C452 (192.168.1.224) está acessível sem autenticação (sessão "Público"). A porta 8081 expõe a OpenAPI do equipamento e a 8080 expõe o serviço gSOAP 2.7. |             |
| EVIDÊNCIA  | <code>http://192.168.1.224/wcd/spa_n → Acesso sem login 8080/tcp open soap gSOAP 2.7 8081/tcp open http Konica Minolta bizhub C452 OpenAPI</code>                                                         |             |
| IMPACTO    | Acesso a trabalhos de impressão anteriores (documentos sensíveis), impressão directa, exposição de endereços SMTP/LDAP nas configurações e potencial acesso a credenciais em texto claro.                 |             |
| REMEDIACÃO | 1. Activar autenticação no painel web da impressora 2. Desactivar acesso anónimo (Público) 3. Actualizar firmware (gSOAP 2.7 tem CVE-2020-15902) 4. Isolar a impressora em VLAN dedicada                  |             |

|            |                                                                                                                                                                                                       |        |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| F-003      | Câmaras IP TP-LINK com painel web exposto                                                                                                                                                             | MEDIUM |
| CVSS SCORE | 5.3                                                                                                                                                                                                   |        |
| DESCRIÇÃO  | Dois dispositivos TP-LINK (192.168.1.199 e 192.168.1.243) com servidor HTTP/HTTPS exposto. Prováveis câmaras IP ou NVR com possível utilização de credenciais default.                                |        |
| EVIDÊNCIA  | 80/tcp open http TP-LINK HTTPD/1.0 443/tcp open https TP-LINK HTTPD/1.0<br>Redirect automático para HTTPS no acesso HTTP                                                                              |        |
| IMPACTO    | Acesso ao feed de vídeo das câmaras de segurança, alteração de configurações e possível acesso a credenciais da rede.                                                                                 |        |
| REMEDIÇÃO  | 1. Alterar credenciais default (admin/admin) 2. Actualizar firmware dos dispositivos 3. Isolar câmaras em VLAN dedicada sem acesso à rede corporate 4. Desactivar acesso web remoto se não necessário |        |

|            |                                                                                                                                                                                                                                                        |      |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| F-004      | Gateway ISP (NOS) com SSH exposto na rede interna                                                                                                                                                                                                      | INFO |
| CVSS SCORE | N/A — Fora de scope                                                                                                                                                                                                                                    |      |
| DESCRIÇÃO  | O equipamento ONT/Router Huawei WAP gerido pela NOS (192.168.1.254) tem o serviço SSH (porta 22) activo e acessível a partir da rede interna. O banner de autenticação expõe a Política de Segurança NOS. Equipamento fora do scope — reportado à NOS. |      |
| EVIDÊNCIA  | 22/tcp open ssh Huawei WAP sshd 1.5 (protocol 2.0) Banner: Política de<br>Seguranca NOS – Acesso e Utilizacao... Autenticação NÃO tentada – teste<br>interrompido                                                                                      |      |
| IMPACTO    | Um utilizador interno malicioso poderia tentar autenticação no equipamento, potencialmente obtendo acesso à consola de gestão do gateway ISP.                                                                                                          |      |
| REMEDIÇÃO  | 1. Reportado à NOS via responsible disclosure 2. NOS deve desactivar SSH ou restringir por IP de gestão 3. Actualizar firmware (sshd 1.5 desactualizado)                                                                                               |      |

## 05

# Conclusão e Próximos Passos

A auditoria identificou **4 findings** na infraestrutura de rede interna, sendo 2 de severidade HIGH e 1 de severidade MEDIUM. Os riscos mais críticos relacionam-se com o acesso não autenticado ao switch de rede e à impressora multifunções, que poderiam ser explorados por um atacante interno para comprometer a confidencialidade e integridade da rede.

Adicionalmente, foi identificado e reportado de forma responsável à NOS (Responsible Disclosure) um finding no equipamento gateway do ISP, demonstrando boas práticas de cibersegurança.

| PRIORIDADE  | ACÇÃO                                                         | PRAZO     |
|-------------|---------------------------------------------------------------|-----------|
| IMEDIATA    | Activar autenticação no switch gerido e na impressora         | 48 horas  |
| CURTO PRAZO | Actualizar firmware de todos os dispositivos de rede          | 2 semanas |
| CURTO PRAZO | Segmentar dispositivos IoT em VLANs dedicadas                 | 1 mês     |
| MÉDIO PRAZO | Implementar política de gestão de acessos (NAC)               | 3 meses   |
| MÉDIO PRAZO | Realizar novo pentest após remediação para verificar eficácia | 3 meses   |